

MFA Attestation for Plaid Production Access

Version: 2026-06-26.1 **Owner:** Chris Sam, Founder — GoldFin Desk **Scope:** Plaid Production Access questionnaire — security & access control section

Plaid question answered by this document

> "Is multi-factor authentication (MFA) in place for access to critical systems that store or process consumer financial data?"

Answer

Yes. Every identity — end user, employee, contractor, and sub-processor — that can reach a critical system storing or processing consumer financial data obtained through Plaid authenticates with multi-factor authentication. **There is no password-only path anywhere in the product or in any operator console.** Both supported authentication paths satisfy NIST SP 800-63B AAL2.

Critical systems in scope

The following are the systems where consumer financial data is created, transmitted, processed, or stored. MFA is enforced on every one of them.

#	Critical system	Holds / processes Plaid data?	Who can access	MFA enforcement
1	GoldFin customer portal (/portal/*)	Yes — accounts, balances, transactions, advisory reports	End users	Email OTP (6-digit, single-use, 10-min TTL) or Google OAuth with 2-Step Verification required. No password form.
2	Admin / audit dashboard (/portal/admin/audit)	Yes — read access to all user-linked Plaid data	Admin role only, checked via <code>has_role(auth.uid(), 'admin')</code> RLS	Same passwordless flow as users; admin gate is server-side, not UI-side.
3	Edge functions calling Plaid (plaid-*, cron-run-reports)	Yes — exchange public tokens, fetch accounts, run reports	Service identity + per-call <code>auth.uid()</code> re-verification	JWT validated on every call; cron uses <code>CRON_SECRET</code> stored in DB vault.

#	Critical system	Holds / processes Plaid data?	Who can access	MFA enforcement
4	Lovable Cloud database (Postgres) holding <code>plaid_items</code> , <code>plaid_accounts</code> , <code>plaid_transactions</code> , <code>advisory_reports</code>	Yes — source of truth	Operators via vendor console	Vendor console MFA (TOTP) required on every operator account; service-role key is never exposed and never used from the browser.
5	Plaid Dashboard	Yes — keys, webhooks, items	Founder + engineering lead	Plaid Dashboard MFA (TOTP) required; recovery codes sealed in a password manager vault.
6	Stripe Dashboard (drives subscription gating for reports)	Indirect — controls who receives Plaid-derived reports	Founder	Stripe MFA (TOTP + hardware key) required.
7	Resend (transactional email — OTP codes, reports)	Indirect — delivers OTPs and reports	Founder	Resend MFA (TOTP) required.
8	Source-code repository (GitHub)	Indirect — controls code that handles Plaid data	Founder + engineering lead	GitHub MFA (hardware key, TOTP fallback) required; branch protection on <code>main</code> .
9	Domain registrar & DNS	Indirect — controls <code>goldfindesk.com</code> and email DNS	Founder	Registrar MFA (TOTP) required; registrar lock enabled.

End-user MFA — how it works

Path	Factor 1 (something you have)	Factor 2 (something you can prove)	Notes
Email OTP	Control of verified email mailbox	6-digit one-time code delivered out-of-band	Single-use, 10-min TTL, server-stored as SHA-256, rate-limited (5 issuances/hour, 5 verifies/code)
Google OAuth	Possession of Google account	Google-enforced 2-Step Verification	Federated; 2SV required on the Google account during onboarding

Knowledge-based auth, SMS OTP, and security questions are **explicitly out of scope** — none are used anywhere.

Privileged / admin MFA

- Admin role lives in a separate `user_roles` table — never on the user/profile row — and is gated by the `public.has_role()` security-definer function used inside every relevant RLS policy.
- Admins authenticate via the **exact same** Email OTP or Google OAuth flow as end users. There is no separate admin login surface and no shared credential.
- The audit dashboard at `/portal/admin/audit` is server-side gated by `has_role(auth.uid(), 'admin')`.

Plaid Link — fresh-auth requirement

Before `plaid-create-link-token` returns a token, the requesting session must have completed an authentication assertion within the last 30 minutes. A stale session cannot initiate a new bank link, exchange a public token, or change linked accounts without re-authenticating with the user's second factor.

Vendor / operator console MFA

Every third-party console that can read, write, or influence Plaid-derived data requires MFA on every operator account. Recovery codes are sealed in a password-manager vault accessible only to the founder. Quarterly review confirms that MFA is still enforced and that no shared logins exist.

Enforcement evidence (independently verifiable)

- **No password UI exists.** There is no username/password form anywhere in the product. Code search for password input fields returns zero results in `src/pages/portal/*`.
- **Legacy auth paths redirect.** `/portal/signup`, `/portal/forgot-password`, and `/portal/reset-password` all route to the single passwordless login at `/portal/login` (see `src/portal/PortalRouter.tsx`).
- **Every protected route is wrapped** by `ProtectedRoute`; unauthenticated requests redirect to login.
- **Every Plaid edge function re-verifies** `auth.uid()` server-side on every call — the JWT is validated, the user is matched to the Plaid item, and the call fails closed if either check fails.
- **Refresh-token rotation** is enabled; a reused refresh token revokes the entire session family.
- **Session limits:** access token 1 hour, idle timeout 30 minutes, absolute timeout 24 hours.
- **Auth events are logged** to the admin audit dashboard (issued, verified, failed, rate-limited, locked) and webhook deliveries are retained 90 days in `webhook_events`.

Standards alignment

This control set is aligned with:

- **Plaid EUSA §5** (security & confidentiality obligations)
- **Plaid Production Access review** — authentication and session management
- **NIST SP 800-63B AAL2** — multi-factor authentication
- **SOC 2 CC6.1 / CC6.6** — logical access and authentication
- **PCI-DSS 8.4** — strong authentication for all access to systems handling cardholder/financial data

Review cadence

This attestation is reviewed:

- **Quarterly** by the founder and engineering lead (logged in the admin audit dashboard).
- **On trigger** — after any authentication incident, change to the auth surface, addition of a new identity provider, or new Plaid product surface.
- **Annually** against the current NIST 800-63B revision and SOC 2 control set.

Attestation

I, **Chris Sam**, Founder of GoldFin Desk, attest that the controls described above are implemented and operating as stated as of the version date below. Suspected authentication issues should be reported to **security@goldfindesk.com**.

Signed: Chris Sam, Founder **Date:** 2026-06-26 **Version:** 2026-06-26.1

Linked documentation

- Full MFA Policy (web): goldfindesk.com/mfa-policy — PDF: goldfindesk.com/downloads/goldfin-mfa-policy.pdf
- Plaid Operations & Maturity Policy (web): goldfindesk.com/plaid-operations — PDF: goldfindesk.com/downloads/goldfin-plaid-operations-policy.pdf
- Data Retention & Deletion Policy: goldfindesk.com/data-retention